FUNDHUB LLC

INFORMATION SECURITY POLICY

Version 1.2 | Reviewed November 6, 2026 (Arizona) | Policy owner: Chris Stanbridge

1. PURPOSE AND SCOPE

Fundhub protects the confidentiality, integrity, and availability of its customer, employee, contractor, and bank-connection data. This policy applies to people and devices with access to Fundhub production code, hosting, databases, logs, Plaid, and other service providers. The owner reviews it at least quarterly and after a material change or security incident. The operational runbook is docs/sops/RUNBOOK.md.

2. ACCESS AND AUTHENTICATION

Each person uses an individual account and the least access needed for their role. The owner reviews privileged access quarterly and removes or changes access when duties change or a person leaves. Production-critical provider accounts require a second sign-in factor. Recovery codes are stored in the account owner's password manager, not in source or shared messages. Fundhub account creation and normal sign-in precede passkey setup. Client, affiliate and company bank connections require a separate server-verified passkey assertion before Plaid opens and before the connection is saved, plus explicit consent. Passkey registration alone is insufficient. Supported authenticators may use Face ID, fingerprint or their local unlock code; Fundhub does not receive biometric samples. Recovery requires a recent primary sign-in and an unused recovery code. Old access and codes remain valid until a replacement passkey is successfully verified; the replacement then needs a separate assertion. An access requirement is recorded as implemented only after the live setting and sign-in path are verified.

3. DATA AND SECRETS

Secrets belong in provider-managed environment settings, never in source control. Plaid access tokens are encrypted before database storage. Public production traffic uses HTTPS. Application database connections require TLS 1.2 or newer, trusted certificate and hostname verification; plaintext is limited to explicitly disposable local test databases. Data received from Plaid is stored in Fundhub's Supabase database, whose published policy covers database data and backups with AES-256. The processor inventory also includes Twilio, Resend, Anthropic, Inngest and Netlify, which publish encryption-at-rest commitments; inventory membership does not attest to actual data delivery. Recipient mailboxes, carrier systems and personal phones are outside Fundhub's managed storage boundary. Access to consumer data is role scoped and logged where supported. Consent for bank linking records the exact text, scope, version, account, target, time and durable verified assertion reference, and is retained for review subject to an explicit erasure request.

4. CHANGE AND VULNERABILITY MANAGEMENT

Code changes receive automated lint, type checks where installed, focused tests, independent review for production-risk changes, and protected release checks. Production dependencies are scanned on a recurring schedule; coverage must also include production assets and devices. A finding is assigned an owner and due date; critical findings target repair within 7 days and high findings within 30 days, or sooner if a provider deadline applies. Due dates retain the original observation date instead of resetting on each scan. A fix is rescanned; a compensating control does not change an unpatched advisory into a passing dependency scan. Employee and contractor devices with production access belong in the scan inventory and require current protection. Missing coverage and device evidence are open gaps, not completed controls.

5. INCIDENT RESPONSE

The first responder records the time and affected system, limits exposure by suspending the credential or session, and preserves relevant logs. The owner determines affected data and people, rotates exposed keys, coordinates provider support, and records containment, recovery, notifications, and follow-up actions. Restore service through the tested release and backup procedures. The owner reviews the incident and updates controls. Availability incident steps and emergency contacts are in docs/sops/RUNBOOK.md.

6. RETENTION AND DELETION

Keep consumer data only while needed for the service and applicable obligations. Review each data class and retention period quarterly. A monthly job records count-only review receipts and does not delete customer records. Actual deletion requires signed retention periods, an owner/admin session with recently verified MFA, a dry-run review, and a durable receipt in the same transaction as the change. Deletion is manual until an approved schedule is implemented and verified. An individual erasure request follows the separate erasure procedure and preserves only records that must lawfully remain.

7. VENDORS AND EVIDENCE

The owner maintains a list of providers with access to sensitive data and reviews their access and security evidence. Control claims for Plaid or any other reviewer reflect observed production settings and retained test or provider receipts. Source code or this policy alone does not prove that a setting is active in production.

IMPLEMENTATION STATUS AT REVIEW

November 6 deployment followed 14 passing required checks and successful Ship. It includes bank-only passkeys, scoped one-use challenges, recovery, versioned consent, strict database TLS and the findings ledger. Seven checked files, including the associated-domain file, matched. Live passkey GET returned 405; unauthenticated POST returned 401. Isolated checks passed: 17 restricted-role PostgreSQL and 12 real-signature browser checks. Customer login, production positive assertion, bank connection, provider delivery and physical Face ID/fingerprint/native passkeys remain unproved. This review created no synthetic production records.

Current GitHub and Netlify operator MFA and the sole active Plaid administrator's 2FA are enabled. Supabase's current-account authenticator does not establish production-organization coverage. Full workforce and critical-provider MFA coverage and current privileged-access review remain unverified. iOS 1.0.4/build 10 and Mac development binaries have Fundhub signatures and associated-domain entitlements; distribution, updated Mac installation and physical-device proof remain pending. Older apps offer external browser fallback.

Deployed-revision scan history, audit, reporting, upload and ledger tracking succeeded; no findings overdue. Production dependencies remain zero critical, two high and five moderate packages; severity gate failed. Chris Stanbridge owns findings, retaining the earliest verified November 3 observation and December 3 deadlines. Live Inngest limits preserve official signature verification; unsigned GET returned 401. This bounded compensating control does not patch the SDK. All-device scan coverage remains unverified.

Six signed default-company periods: credit raw payloads, SSN-access logs and soft-pull ledger, 762 days; bank transactions, 731; demo data, 7; broker uploads intentionally retained without scheduled purge. Counsel review remains unproved. Monthly count-only review is first due December 1, not overdue. No production baseline count, manual receipt or deletion occurred. Broader retention coverage, provider deletion/remote Plaid Item removal, backup/restore proof and recipient/export handling remain open.

Public TLS 1.2 passed; 1.1 was refused. Post-release read-only metadata checks used authorized TLS 1.3 as fundhub_app, without superuser or RLS-bypass privileges. Five new passkey tables force RLS and deny anonymous/authenticated SELECT; nine enabled trigger bodies matched source. Application-to-pooler TLS is proved; the managed pooler-to-database hop reported no TLS.

PROVIDER EVIDENCE REVIEWED NOVEMBER 6, 2026

Supabase: https://supabase.com/legal/privacy-resources/data-residency-and-transfers-faq

Twilio: https://www.twilio.com/en-us/legal/security-overview

Resend: https://resend.com/security

Anthropic: https://trust.anthropic.com/faq

Inngest: https://www.inngest.com/docs/platform-and-operations/cloud-architecture-and-security

Netlify: https://www.netlify.com/security/